

Good afternoon,

This email serves as an **official notification obligation** to submit a **suspected data breach** to the **General Data Protection Regulation (GDPR) of the European Union** under Article 33 1 section 1 - *Notification of a Personal Data Breach to the Supervisory Authority* and Article 34 sections 1 and 2 - *Communication of a Personal Data Breach to the Data Subject*.

My name is Will Knight, a security analyst from the security team of Clifford Chance. According to our records, a request was submitted to assess the data breach and legal implications of unprotected client sensitive personally identifiable information (SPII).

Recap of Events: A scheduled software update for the Great New Games web shop was set to take place on 21 July 2026. After the update was enacted, the SPII of 4,000+ customers became publically available and unencrypted for a period of up to 6 days. A subsequent update was initiated on 30 July 2026 which identified this anomaly and the data leak was then closed. At present, it is unclear if the unencrypted database received unauthorized access from non-organizational persons.

GDPR Violation and Explanation:

Under Article 33 section 1 of the General Data Protection Regulation (GDPR):

In the case of a personal data breach, the controller shall without undue delay and where feasible, not later than 72 hours after becoming aware of it, notify the personal data breach to the supervisory authority competent in accordance with Article 55, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons.

Personal data, Article 2 section 12, states *a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure, of or access to, personal data transmitted, stored or otherwise processed*. The unencrypted and publically available release of SPII during the period of the 6 days between updates classifies as a personal data breach.

The data controller (legal person/public authority/agency) must report a suspected data breach up to 72 hours after it was discovered. At this time, the secondary update which closed the data breach was initiated on 30 July 2026. At present, the event has been discovered and is still within the window of 72 hours to report the data breach to the GDPR.

The supervisory authority, Article 2 section 21, is an *independent public authority which is established by a Member State*. They are responsible for the monitoring of processing of personal data within the Union in accordance to Chapter VII of the GDPR.

It is advised under Article 33 section 3a-d that when a notification is submitted under Article 33 to the GDPR, the following information is included:

(a) describe the nature of the personal data breach including where possible the categories and approximate number of data subjects concerned and the categories and approximate number of personal data records concerned;

(b) communicate the name and contact details of the data protection officer or other contact point where more information can be obtained;

(c) describe the likely consequences of the personal data breach;

(d) describe the measures taken or proposed to be taken by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

Only relevant information is required to submit for the GDPR case. Exemptions to sensitive information such as private operations will not need to be disclosed.

Under Article 33 sections 1 and 2 of the General Data Protection Regulation (GDPR):

1. When the personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the controller shall communicate the personal data breach to the data subject without undue delay.

2. The communication to the data subject referred to in paragraph 1 of this Article shall describe in clear and plain language the nature of the personal breach and contain at least the information and measures to points b, c, and d of Article 33.

In consideration that the data breach contained SPII such as credit card information, it is strongly advised to take immediate action by reaching out to the suspected customers of Great New Games and inform them of the data breach. It is imperative for the customers to understand the situation, what current steps are being taken, and how at risk they are of a breach event.

Legal Ramifications:

After reviewing the General Data Protection Regulation legal ramifications of a data breach event involving SPII, regulators may conclude on the following violations:

Article 32 - Security of Processing — breach of paragraph 1 sections b and d

Article 25 - Failure of Privacy by Design/Default - breach of paragraph 1 section a

Breach of Article 32 section b and d. Regulators may conclude that the data breach was a result of the failure of regulatory testing the effectiveness of organizational measures for the security of processing data which led to the inability to ensure ongoing confidential processing of systems and services.

Breach of Article 25 section a. Regulators may conclude that the data breach was a result of the lack of implementation of data-protection principles in an effective capacity to meet the necessary processing safeguards and rights of data subjects.

Estimated fines and penalties for this data breach event are uncertain. The GDPR assesses fines in one of two tiers; Tier 1, up to 10 million Euros or 2% of total global annual turnover or Tier 2, up to 20 million Euros or 4% of total global annual turnover. Assessing the fines are based on weight of factors.

Factors increasing the fines for this event could be as a result of sensitive data types, duration of leak, suspected negligence and lack of visibility. However, the mitigating factors which would reduce the fines for this event could be a result of the limited scope (only 4,000 affected customers out of 2.5 million), prompt remediation by initiation of the second update, and further cooperation.

Along with these fines, the other ramifications that could occur are private litigation by these suspected customers, reputational damage, and mandatory audits into continued business operations. At this time, it is undetermined what the regulators will assess, but all possibilities have been presented here.

Conclusion:

It is greatly unfortunate that a data breach of any SPII may have resulted in the release of unencrypted information without swift action taken in the moment. However, considering the actions made by Great New Games to mitigate the effects and report this as soon as possible are strong considerations in the grand scheme of doing the right thing.

As recommended, following this email, an Article 33 notification must be submitted to the GRDP with the information included in sections 3 subsections a-d.

Please feel free to respond to this email with any questions, comments, or concerns that you may have regarding next steps and I will be available to provide answers moving forward.